



IDS e agenti sulle macchine

Riconoscere che qualcosa è cambiato in un modo che riguarda la sicurezza, e vedere dall'interno ciò che dalla rete non si vede. Nessuno chiama indietro.

14/09/2026 11:25

Riconoscere che qualcosa è cambiato in un modo che riguarda la sicurezza, e vedere dall'interno ciò che dalla rete non si vede. Nessuno chiama indietro.

Riferimenti	
Sorgente	17_IDS_E_AGENTI.md
Prodotto	snap - Secure Network Assessment Platform

Contenuto del documento
1. Scopo e portata
2. Riferimenti
3. Decisioni assunte
4. Architettura
5. Catalogo delle regole (prima serie)
6. L'agente di macchina
7. Requisiti
8. Privacy e conformità
9. Come si legge: sei casi
10. Limiti dichiarati

Documento generato dal sorgente in docs/: se il contenuto cambia, cambia il sorgente e questo PDF si rigenera. Una copia modificata a mano sarebbe una seconda verità'.

14/09/2026 11:25 · periodo di riferimento: documentazione di prodotto

Sommario

1. Scopo e portata	3
1.1 Che cosa questo IDS è, e che cosa non è	3
2. Riferimenti	3
3. Decisioni assunte	3
4. Architettura	5
4.1 Il ciclo dell'IDS	5
4.1-bis Dove stanno i dati, e come si chiamano	5
4.2 I sensori (punto d'innesto)	6
4.3 Il sensore del traffico	6
Senza dipendenze nuove	6
Che cosa si legge, e che cosa no	6
Con e senza porta mirror	7
La sonda non si denuncia da sola	7
Riconoscere un nome che trasporta dati	7
I tetti	7
4.4 Guardare i pacchetti	7
Perché i pacchetti passano dall'archivio	8
La ritenzione più stretta di tutto il prodotto	8
Tre difetti trovati guardando la pagina	8
5. Catalogo delle regole (prima serie)	8
6. L'agente di macchina	8
6.1 Che cosa raccoglie: quindici gruppi dichiarati	8
6.1-bis Due ritmi, e perché	9
6.2 Che cosa NON raccoglie, per scelta	9
6.3 Ciclo di vita: il pacchetto	9
6.4 Dentro un container: che cosa vede e che cosa dichiara	10
7. Requisiti	10
8. Privacy e conformità	11
9. Come si legge: sei casi	11
Caso 1 – La porta di amministrazione comparsa	11
Caso 2 – Lo stesso indirizzo con una scheda di rete diversa	11
Caso 3 – SMB 1.0 riaccesso	11
Caso 4 – L'antivirus fermo, visto da dentro	12
Caso 5 – Il disco che finisce	12
Caso 6 – Il silenzio delle prime dodici ore	12
Come si usa la pagina in un turno	12
10. Limiti dichiarati	12

DOCUMENTO	RILEVAZIONE DELLE INTRUSIONI (IDS) E AGENTI DI MACCHINA
Versione documentata	console 1.8.8, sonda 1.3.6, agente 1.2.2
Conformità	ISO/IEC/IEEE 29148:2018 (§1 scopo, §2 riferimenti, §3 requisiti), NIS2 art. 21, CRA all. I
Aggiornato	2026-09-13

1. Scopo e portata

Il prodotto sa che cosa c'è in rete e se risponde. Questo documento aggiunge due cose che oggi mancano:

- 1. l'IDS: riconoscere che qualcosa è cambiato in un modo che riguarda la sicurezza — un indirizzo che cambia scheda di rete, una porta di amministrazione comparsa dove non c'era, un apparato mai visto in rete alle tre di notte;
- 2. l'agente di macchina: portare dentro il sistema quello che dall'esterno non si può vedere — chi ha provato ad accedere, quale processo tiene aperta una porta, se il disco sta finendo, se il servizio di sicurezza è stato fermato.

Non sono due funzioni separate: l'agente è il sensore più informato dell'IDS. Una porta 4444 aperta vista dalla rete è una porta aperta; vista dall'agente è nc.exe avviato dall'utente mrossi dieci minuti fa.

1.1 Che cosa questo IDS è, e che cosa non è

È un motore di rilevazione su osservazione: confronta ciò che la sonda e gli agenti vedono adesso con ciò che era normale prima, e applica un catalogo di regole dichiarate.

Vede anche il traffico, da quando esiste il sensore traffico (§4.3), ma di esso legge le intestazioni e i nomi dichiarati in chiaro — chi parla con chi, con quale protocollo, con che ritmo, verso quale dominio — e mai il contenuto: si catturano poche centinaia di byte per pacchetto e se ne estraggono quei campi.

Non è quindi un sistema a firme sul payload: non riconosce un exploit dal suo contenuto, né legge dentro un canale cifrato. Riconosce invece cose che il payload non direbbe comunque — un avvelenamento ARP, un DHCP abusivo, un ritmo da orologio verso l'esterno — e lo fa senza aprire ciò che le persone scrivono.

Questo limite è dichiarato in ogni pagina che mostra rilevazioni. Un prodotto che lasciasse credere il contrario sarebbe peggio di uno che non rileva niente: darebbe una sicurezza che non ha.

2. Riferimenti

DOCUMENTO	CHE COSA NE SERVE QUI
03_PROTOCOLLO_SNAP_SEC.md	La direzione delle connessioni: chi sta più in basso apre verso chi sta più in alto. L'agente segue la stessa regola
06_INVENTARIO_E_MONITOR.md	Le osservazioni su cui lavora il sensore d'inventario
11_SALA_OPERATIVA.md	Dove finiscono le rilevazioni nel turno di chi guarda
14_MOTORE_DI_SCANSIONE.md	Le fasi che producono le osservazioni
MITRE ATT&CK	Ogni regola dichiara la tecnica che riconosce

3. Decisioni assunte

ID	DECISIONE	PERCHÉ
I D S -	Il motore gira sulla sonda, non sul server	La sonda è l'unica a contatto con la rete sorvegliata; il server non la raggiunge nemmeno. Rilevare sul server significherebbe rilevare in ritardo, su dati già conferiti
I D S -	Le rilevazioni conferite entrano nel SIEM esistente come eventi, non in un impianto parallelo	Il server ha già regole a soglia, allarmi che si aggiornano invece di duplicarsi e tecniche MITRE. Un secondo impianto avrebbe voluto dire due posti in cui guardare e due verità
I D S -	Ogni regola dichiara codice, gravità, tecnica MITRE e il perché	Una rilevazione senza il motivo è un allarme che si impara a ignorare
I D S -	Il confronto è con una linea di base che si costruisce da sola, e che dichiara da quando esiste	Rilevare "porta nuova" al primo giro significherebbe segnalare l'intera rete. Finché la linea di base è giovane, le rilevazioni si contano ma non si allarmano

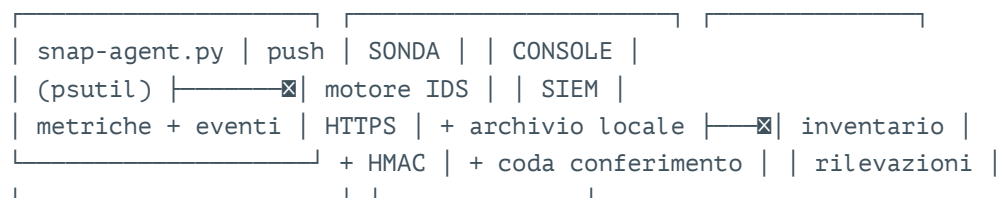
ID	DECISIONE	PERCHÉ
I D S - 0 7	Oltre alla maturità del singolo soggetto vale quella dell'intero archivio: finché la memoria complessiva è più giovane della soglia, le regole che si fondano sull'assenza di memoria non scattano	Imparata sul campo. Un soggetto appena visto non ha memoria per definizione, quindi la sola maturità per soggetto non ferma niente: alla prima passata su una rete vera sono uscite quattrocento rilevazioni HOST-NUOVO in un colpo. Un IDS che al primo avvio segnala l'intera rete viene disattivato il giorno dopo
I D S -	I sensori sono innestabili e ciascuno dichiara di che cosa è capace	È la porta lasciata aperta per il traffico, senza prometterlo oggi
A G - 0 7	La raccolta e' divisa in gruppi dichiarati, e chi installa sceglie quali accendere da un'interfaccia di console sulla macchina	Una pagina web vorrebbe dire un servizio in ascolto su ogni postazione sorvegliata, cioè esattamente cio' che AG-01 evita. I gruppi spenti si dichiarano alla sonda: un gruppo spento non e' un gruppo a zero
A G - 0 8	Le misure (serie storica) e l'inventario (stato) viaggiano separati e con due ritmi: il minuto e l'ora	Misurato su una macchina vera: insieme pesavano 70,7 kB a invio, cioè 99 MB al giorno per macchina, per riscrivere 1.440 volte lo stesso elenco di programmi installati. Separati: 7,6 MB al giorno con piu' informazioni. Non e' solo traffico: un inventario e' uno stato e si sovrascrive, e nella tabella delle misure avrebbe voluto dire conservarne 1.440 copie per poterne leggere una
A G - 0 9	Gli elenchi stanno nell'inventario, i numeri nelle misure	Le porte in ascolto pesavano 4,4 kB al minuto per ripetere lo stesso elenco. Il conteggio resta nelle misure -- e' una serie, e costa quattro byte -- e l'elenco viaggia con l'inventario, che pero' parte subito se quell'elenco cambia: una porta nuova non aspetta l'ora
A G - 1 0	L'agente si installa da un pacchetto generato dalla console della sonda, e il pacchetto e' una credenziale per una macchina	Le tre righe da copiare funzionano quando chi installa ha il repository sottomano; su venti macchine diventano un messaggio inoltrato con un token dentro. Il token resta a uso singolo: una credenziale condivisa fra venti macchine non si potrebbe revocare per una sola
A G - 1 1	Dentro un container, un gruppo o legge la macchina o si dichiara	Trovato provando il container sul serio: software elencava gli 87 pacchetti dell'immagine Debian e aggiornamenti interrogava l'apt del container. Due dati esatti e falsi -- il modo peggiore di sbagliare, perche' nessuna pagina avrebbe mostrato un'anomalia
I D S -	Il sensore del traffico usa libpcap/Npcap via ctypes, senza dipendenze nuove	scapy e' GPLv2 su un prodotto MIT; pypcap e pcap-ng vanno compilate. La C API di libpcap e' stabile da vent'anni e il collegamento sta in duecento righe. Npcap di norma e' gia' installato, perche' lo porta nmap
I D S -	Del traffico si leggono intestazioni e nomi in chiaro, mai il contenuto	I nomi (DNS, SNI, Host) sono cio' che permette di riconoscere un tunnel o un dominio di comando senza aprire un byte di payload. Leggere il contenuto sarebbe un'intercettazione: base giuridica diversa, informativa diversa, e verosimilmente accordo sindacale (art. 4 Stat. lav.)
I D S -	Il sensore nasce spento e si accende dichiarando l'interfaccia	Riguarda il traffico di persone. Un valore predefinito acceso avrebbe fatto cominciare un trattamento senza che nessuno lo decidesse
I D S -	La sonda esclude se stessa dall'osservazione	Scansiona per mestiere: i suoi SYN hanno la forma di una scansione interna, e la prima rilevazione sarebbe la sonda che denuncia se stessa
I D S -	I pacchetti gia' letti si conservano per venti minuti e ventimila righe, e si cancellano spegnendo l'osservazione	Un sensore che non fa vedere su che cosa lavora si accende una volta e non si accende piu'. Ma conservare e' un passo diverso dal contare: la finestra e' di minuti, i limiti sono due (il tempo non basta su una rete attiva, il numero non basta su una rete quieta) e spegnendo non resta niente
I D S -	Il traffico della sonda si vede nell'elenco ma non diventa mai un fatto per le regole	Le due cose erano confuse: l'esclusione scartava i pacchetti prima di decodificarli, e nell'elenco comparivano centotrentasette righe mezze vuote. Escludere serve a non far denunciare la sonda dalle regole, non a renderla illeggibile

ID	DECISIONE	PERCHÉ
A G - 0 1	L'agente apre lui la connessione verso la sonda	Stessa regola della sonda verso il server: una macchina in una rete di utenza non è raggiungibile, e non deve esserlo
A G - 0 2	L'agente si autentica con una chiave propria, emessa alla registrazione, e firma ogni invio (HMAC-SHA256 con marca temporale e nonce)	Senza firma, chiunque sulla rete potrebbe iniettare metriche false e far scattare o tacere le regole
A G - 0 3	L'agente non riceve comandi in questa versione: riceve solo la propria configurazione nella risposta	Un agente che esegue comandi è un canale di esecuzione remota su ogni macchina sorvegliata: si aggiunge quando serve davvero, con la stessa cura del protocollo delle sonde
A G - 0 4	Una sola dipendenza (psutil), dichiarata	Le stesse metriche su Windows e Linux senza scrivere due volte il codice di raccolta. È mantenuta, diffusa e va nell'SBOM
A G - 0 6	Un evento che descrive una condizione (disco pieno, protezione ferma, accessi falliti) si riferisce quando lo stato cambia di fascia, e si riarma dopo sei ore	Imparata sul campo, come IDS-06. Alla prima prova su una macchina vera sono arrivati centootto eventi disco_pieno in ventiquattr'ore, tutti identici: la pagina degli eventi non serviva piu' a niente, perche' una riga nuova sarebbe finita sepolta. Mille volte lo stesso fatto e' un fatto che dura, non mille fatti, ed e' la stessa regola che ids_registra applica alle rilevazioni. Il riarmo esiste perche' un problema che persiste non deve nemmeno sparire in silenzio
A G - 0 5	L'agente non legge il contenuto di file, traffico o messaggi	Raccoglie misure e fatti (chi ha effettuato l'accesso, quale processo ascolta): il contenuto è dato personale altrui e non serve a nessuna delle regole

I valori piu' lunghi di quanto la colonna possa contenere sono abbreviati con i puntini (...); il dato completo resta nell'inventario della console.

4. Architettura

macchina sorvegliata rete del cliente sede



apre lui apre lei risponde

Tre livelli, una regola sola: chi sta più in basso apre verso chi sta più in alto. Nessuno dei tre chiama indietro.

4.1 Il ciclo dell'IDS

Gira nel processo dell'agente della sonda (quello senza interfaccia), a cadenza dichiarata:

1. osserva: ogni sensore abilitato produce osservazioni dall'archivio locale;
2. confronta con la linea di base (che cosa era normale finora);
3. applica le regole: ogni regola guarda le osservazioni del proprio genere;
4. deduplica: la stessa rilevazione sullo stesso soggetto non si ripete, si aggiorna con il conteggio e l'ultima volta;
5. accoda verso il server, come qualunque altro record;
6. aggiorna la linea di base: ciò che è stato rilevato diventa il nuovo normale, altrimenti la stessa cosa si segnalerebbe per sempre.

4.1-bis Dove stanno i dati, e come si chiamano

Le tabelle sono due volte, una per applicativo, e non sono le stesse: sulla sonda c'è ciò che serve a rilevare (la linea di base, le rilevazioni da conferire, le macchine registrate con le loro chiavi); sul server c'è ciò che serve a guardare (le rilevazioni

conferite, con tenant e nodo).

SONDA	SERVER	PERCHÉ NON È LA STESSA TABELLA
local_ids_baseline	—	La memoria di ciò che era normale non lascia mai la sonda: è grande, cambia di continuo e al server non serve
local_ids_findings	ids_findings	Sulla sonda c'è conferita_at (che cosa è già stato consegnato); sul server c'è tenant_id, il nodo, lo stato e la nota di chi ha deciso
local_agents	agent_hosts	La sonda conserva la chiave con cui l'agente firma; il server non la vede e non deve vederla
local_agent_metrics, local_agent_events	agent_metrics, agent_events	Stesso contenuto, due cicli di vita: sulla sonda si cancellano dopo il conferimento, sul server si conservano secondo la ritenzione del tenant

Il prefisso local_ non è un vezzo. Tre di queste tabelle nascevano con lo stesso nome di quelle del server pur avendo colonne diverse. In esercizio non si incontrano — due applicativi, due basi dati — ma chi le mette sullo stesso PostgreSQL (i test lo fanno) trova un CREATE TABLE IF NOT EXISTS che non crea niente, perché la tabella esiste già, e l'indice successivo che fallisce su una colonna inesistente: un guasto che non somiglia per niente alla propria causa. La convenzione era già in uso per local_nodes; adesso vale per tutte, e un test confronta i due schemi a ogni giro.

4.2 I sensori (punto d'innesto)

Un sensore è una classe con quattro cose: codice, nome, disponibile() e osserva(archivio, adesso). Il motore non sa nulla di come l'osservazione sia stata ottenuta.

SENSORE	STATO	CHE COSA VEDE
inventario	attivo	nodi, porte, MAC, ARP letto in SNMP, presenze senza fili, letture SMB — tutto ciò che la sonda già raccoglie
agenti	attivo	accessi, processi in ascolto, utenti, servizi, metriche fuori soglia riferiti dalle macchine
traffico	spento finché non si accende	intestazioni dei pacchetti e nomi in chiaro (DNS, SNI, Host). Nessuna dipendenza nuova: usa libpcap/Npcap via ctypes (§4.3)

Un sensore non disponibile si dichiara nella pagina dei sensori: chi guarda deve sapere che cosa non è stato guardato, e che lo zero di quel sensore non è un "tutto a posto".

4.3 Il sensore del traffico

Nasce spento. Non per prudenza formale: la cattura vede il traffico di chi lavora su quella rete. Si accende dalla Configurazione della sonda, scegliendo l'interfaccia, e la pagina dichiara che cosa legge e che cosa non legge mai prima dell'interruttore, non dopo.

Senza dipendenze nuove

libpcap (Npcap su Windows) espone da vent'anni una C API stabile di cinque funzioni, e ctypes è nella libreria standard: il collegamento sta in duecento righe (cattura.py) e non aggiunge nulla al requirements.txt.

ALTERNATIVA	PERCHÉ NO
scapy	GPLv2 su un prodotto MIT, e porta un dissezionatore universale dove servono quattro intestazioni
pypcap, pcap-ng	licenza buona, ma vanno compilate: su Windows significa una toolchain sulla macchina del cliente
dpkt	ottimo per analizzare, non cattura

Npcap di norma c'è già: lo installa nmap, che la sonda richiede. Nel contenitore i privilegi ci sono già anche loro (NET_RAW, NET_ADMIN, concessi per nmap).

Che cosa si legge, e che cosa no

SI LEGGE	NON SI LEGGE MAI
intestazioni Ethernet, ARP, IP, TCP, UDP	il contenuto dei pacchetti
il dominio di una query DNS	il corpo delle risposte
il nome del server nel TLS (SNI)	nulla del flusso cifrato oltre quel nome
l'intestazione Host di HTTP	il resto della richiesta

Si catturano 512 byte per pacchetto, non il pacchetto intero: il resto non entra nella memoria del processo. Nell'osservatorio finiscono fatti derivati — conteggi, insiemi di nomi, istanti — mai i byte. Un test lo verifica mettendo un segreto dentro un payload e cercandolo in tutto il riassunto.

Il filtro BPF (la sintassi di tcpdump) gira dentro il kernel: ciò che esclude non arriva nemmeno al processo. Quello predefinito prende ARP, DHCP, i protocolli dei nomi, il DNS e l'apertura delle connessioni.

Con e senza porta mirror

Su uno switch alla sonda arriva il traffico diretto a lei più tutto il broadcast. Sembra poco ed è invece dove vivono gli attacchi di segmento. Misurato su una rete reale, venti secondi di ascolto senza alcuna porta mirror:

2577 pacchetti 16 schede di rete distinte sul segmento

32 ARP broadcast 1 DHCP 2 mDNS

SERVE LA PORTA MIRROR?	REGOLE
No, basta il broadcast	ARP-AVVELENAMENTO, ARP-RAFFICA, DHCP-ABUSIVO, NOME-AVVELENATO, MAC-NUOVO-SUL-FILO
Sì	SCANSIONE-INTERNA, BEACONING, DNS-ANOMALO, HTTP-IN-CHIARO (per il traffico di altri)

La pagina dei sensori dichiara quale dei due casi si sta osservando: le regole che non possono scattare non devono sembrare regole che non hanno trovato niente.

La sonda non si denuncia da sola

La sonda scansiona per mestiere: i suoi SYN verso mille indirizzi hanno la forma esatta di una SCANSIONE-INTERNA. I suoi indirizzi — MAC e IP — sono esclusi dall'osservatorio, e un test lo verifica. Senza, la prima rilevazione del sensore sarebbe la sonda che segnala sé stessa: il genere di falso positivo che fa spegnere un prodotto.

Per la stessa ragione BEACONING pretende che la destinazione sia fuori dal perimetro dichiarato: dentro la rete tutto è regolare — il monitoraggio, i backup, la sonda — e senza quel filtro la regola segnalerebbe l'infrastruttura del cliente.

Riconoscere un nome che trasporta dati

Il primo tentativo usava l'entropia di Shannon. Misurata su nomi veri, non distingue niente: su un'etichetta corta l'entropia conta in pratica quanti caratteri distinti ci sono, che per una parola breve è quasi la lunghezza.

ETICHETTA	ENTROPIA	VOCALI
sharepoint (vera)	3,32	0,40
xk4mz9qp7wv2 (generata)	3,58	0,00

Due cose completamente diverse a due decimi l'una dall'altra. La misura che le separa è la pronunciabilità: un nome scritto da una persona ha vocali, una stringa codificata no. Si giudica solo da dodici caratteri in su, perché le sigle corte senza vocali (srv, ns1, vpn) sono normali. Provata su dodici nomi veri presi dalla cattura: nessun falso positivo.

I tetti

Ogni contenitore dell'osservatorio ha un massimo, e superarlo si dichiara. Non è prudenza generica: un osservatorio che cresce con il traffico si riempie da solo quando qualcuno manda rumore, e riempire la memoria della sonda è un modo economico per farla smettere di guardare — la prima cosa che farebbe chi sa che c'è.

4.4 Guardare i pacchetti

Un sensore che produce rilevazioni senza far vedere su che cosa lavora si accende una volta e poi non si accende più. La console della sonda ha una pagina Pacchetti con tre modi di guardare la stessa finestra, perché sono tre domande diverse.

SCHEDA	RISPONDE A	CONTIENE
Pacchetti	che cosa passa	istante, protocollo, indirizzi, porte, bandiere TCP, byte, e il nome se il protocollo lo dichiara. L'ARP è tradotto: «chi ha 10.20.10.41? lo chiede 10.20.10.1»
Chi parla con chi	chi sta parlando	le conversazioni aggregate: sorgente, destinazione, porta, quanti pacchetti, quanti byte, per quanto tempo
Nomi richiesti	dove si sta andando	i domini, con quante volte e da quante macchine diverse

Si cerca per indirizzo, MAC o nome, e si filtra per protocollo.

Perché i pacchetti passano dall'archivio

La cattura vive nel processo dell'agente di raccolta; la pagina gira in quello dell'interfaccia. Sono due processi, e l'unica cosa che condividono è l'archivio: l'anello di memoria dei pacchetti già letti viene travasato lì a ogni giro del ciclo (quindici secondi), non a ogni passata dell'IDS — altrimenti la pagina si aggiornerebbe una volta ogni cinque minuti.

La ritenzione più stretta di tutto il prodotto

QUANTO A LUNGO	20 MINUTI
Quanti pacchetti	20.000, i più recenti
Allo spegnimento	la tabella si svuota del tutto

Due limiti e non uno: il tempo da solo non basta su una rete molto attiva (un minuto può valere centomila righe), il numero da solo non basta su una rete quieta (mille righe possono coprire un giorno, ed è esattamente ciò che non si vuole conservare). Serve a guardare che cosa sta succedendo adesso, non a tenere un registro di ciò che le persone fanno. E ciò che si conserva sono i campi, mai i byte: vale qui la stessa regola di §4.3, verificata da un test che mette un segreto dentro un payload e lo cerca in tutto ciò che finisce nell'archivio.

Tre difetti trovati guardando la pagina

Non ragionandoci sopra: aprendola con i pacchetti veri di una rete.

COSA SI VEDEVA	PERCHÉ	COME SI È CORRETTO
137 righe con protocollo «?»	erano i pacchetti della sonda stessa: l'esclusione li scartava prima di decodificarli	una regola sola: il traffico della sonda si vede ma non diventa mai un fatto per le regole
colonna dei nomi vuota, con 12 pacchetti DNS visti	si leggeva il nome solo dalle domande; in una risposta la porta 53 è quella di origine	il nome si legge da entrambe, e nelle statistiche del tunnel entra solo la domanda — contarle tutte e due raddoppierebbe ogni conteggio
TLS e HTTP senza nome nelle risposte	il controllo era sulla porta di destinazione, che in una risposta è quella effimera del client	si guardano entrambe le porte

5. Catalogo delle regole (prima serie)

Ogni regola: codice, che cosa riconosce, gravità, tecnica MITRE, e il perché conta.

CODICE	RICONOSCE	GRAVITÀ	ATT&CK
ARP-MAC-CAMBIATO	Lo stesso indirizzo IP risponde con una scheda di rete diversa	alta	T1557
ARP-MAC-MULTIPLIO	Lo stesso MAC compare su molti indirizzi	media	T1557
HOST-NUOVO	Un dispositivo mai visto compare in una rete dichiarata	media	T1200
PORTA-AMMINISTRAZIONE	Compare SSH, RDP, VNC, WinRM dove non c'era	alta	T1021
PORTA-INSOLITA	Compare una porta alta non standard su un nodo stabile	media	T1571
SERVIZIO-SPARITO	Un servizio che rispondeva da settimane smette	media	T1489
SMB1-RIACCESO	Un nodo torna ad accettare il dialetto SMB 1.0	alta	T1210
WIFI-NOTTURNO	Un apparato mai visto compare sulla rete senza fili in orario di chiusura	media	T1200
ACCESSI-FALLITI	Tentativi di accesso falliti ripetuti su una macchina	alta	T1110
UTENTE-NUOVO	Un'utenza nuova, o aggiunta agli amministratori	alta	T1136
SICUREZZA-FERMA	Servizio di sicurezza (antivirus, firewall) fermo	critica	T1562
ASCOLTO-NUOVO	Un processo nuovo si mette in ascolto su una porta	alta	T1571

Le soglie e le finestre sono per tenant e modificabili: un ufficio con turni notturni e un magazzino chiuso alle 18 non hanno la stessa idea di "orario insolito".

6. L'agente di macchina

6.1 Che cosa raccoglie: quindici gruppi dichiarati

Ogni gruppo dichiara che cosa manda, con quale ritmo, di quali privilegi ha bisogno e se riguarda le persone. L'ultimo campo non è decorativo: è quello che chi installa guarda per decidere, e quello che il titolare del trattamento deve poter leggere senza

aprire il codice (GDPR art. 5, minimizzazione).

GRUPPO	RITMO	PERSONE	CHE COSA MANDA
identità	inventario	no	nome, sistema e build, architettura, CPU, memoria totale, produttore, modello, numero di serie, BIOS e sua data, virtualizzazione, interfacce con MAC e velocità, gateway, DNS
carico	misure	no	CPU, memoria, swap, carico medio, temperature, batteria
dischi	misure	no	spazio per punto di mount, filesystem, inode, cifratura del volume
rete	misure	no	ritmo del traffico in entrata e uscita
connessioni	misure	no	quante per stato, verso quanti indirizzi distinti, porte remote più frequenti – conteggi, non l'elenco di chi parla con chi
processi	misure	sì	quanti, e i primi per CPU e memoria: nome e utente
in_ascolto	inventario	sì	porta, processo, utente, e se è raggiungibile dalla rete o solo dalla macchina
utenti	misure	sì	chi è collegato adesso e da dove
utenze	inventario	sì	utenze locali, amministratori, attive o disattivate, password che non scade
sicurezza	inventario	no	antivirus e loro stato, firewall, SMB 1.0, desktop remoto e NLA, controllo account, avvio protetto, età delle firme, SELinux/AppArmor, SSH
aggiornamenti	inventario	no	quanti in attesa, quanti di sicurezza, ultimo installato, riavvio in attesa
software	inventario	no	nome e versione dei programmi installati
servizi	inventario	no	servizi in esecuzione, e quelli automatici che non sono partiti
pianificate	inventario	no	nomi e stato delle attività pianificate e dei cron
container	inventario	no	nome e immagine dei container attivi

Il software installato è il gruppo che paga di più. Sapere che su quaranta macchine c'è una versione vulnerabile di un programma non richiede di scansionarle una per una, e non richiede che quel programma esponga una porta.

Tre preselezioni: tutti (predefinito), consigliato (senza software e pianificate), minimo (identità, carico, dischi, rete: nulla che riguardi le persone, per dove il trattamento non è stato concordato).

6.1-bis Due ritmi, e perché

	CONTENUTO	OGNI QUANTO	NATURA
Misure	i numeri	un minuto	serie storica: si accumula, si cancella per anzianità
Inventario	gli elenchi	un'ora, o appena cambia	stato: si sovrascrive

Misurato su una macchina reale (Windows 11, 282 programmi, 315 servizi):

	KB PER INVIO	MB AL GIORNO
Tutto insieme, ogni minuto (com'era)	70,7	99,4
Misure ogni minuto + inventario ogni ora	4,3 + 65,7	7,6

Tredici volte meno, con sei gruppi in più di quanti ne mandasse prima. E l'inventario, essendo uno stato, non riempie la tabella delle misure con 1.440 copie al giorno dello stesso elenco.

L'inventario non aspetta l'ora quando le porte in ascolto cambiano: parte subito, perché è esattamente la cosa per cui si guarda quella pagina.

6.2 Che cosa NON raccoglie, per scelta

Contenuto di file, righe di comando complete, traffico, messaggi, cronologia. Le righe di comando possono contenere password passate come argomento: si registra il nome del processo e il suo utente, non come è stato invocato.

6.3 Ciclo di vita: il pacchetto

L'agente si installa da un pacchetto che la console della sonda costruisce: dentro ci sono l'agente, gli installatori per Windows, Linux e Docker, il LEGGIMI e un pacchetto.json con indirizzo della sonda e token.

Windows `.\installa.ps1` attività pianificata, come SYSTEM

Linux `sudo ./installa.sh` unit systemd, utenza dedicata (root con `--privilegi-completi`)

Docker `docker compose up -d` container, macchina montata in sola lettura

Ogni installatore fa la stessa sequenza – Python, ambiente virtuale, psutil, registrazione, cancellazione del token, servizio – e finisce verificando che il servizio stia davvero girando. Un installatore che stampa un esito positivo su un servizio che non è

partito fa perdere più tempo di uno che fallisce.

Il pacchetto è una credenziale: il token dentro vale un'ora e una volta sola, e un pacchetto vale per una macchina. Dieci macchine, dieci pacchetti, dieci credenziali revocabili una per una.

Senza accesso a Internet — nella PA la norma, non l'eccezione — le wheel di psutil si mettono nella cartella wheels/ del pacchetto e gli installatori le usano senza cercare la rete.

A regime l'agente invia ogni intervallo secondi (predefinito 60), firmando ciascun invio. La risposta della sonda porta la configurazione: intervallo e soglie. Un agente che non riesce a parlare accumula in memoria e riprova: la rete che si interrompe non deve perdere gli eventi di sicurezza.

6.4 Dentro un container: che cosa vede e che cosa dichiara

Un agente dentro un container misura il container: due processi, un filesystem che non esiste sulla macchina. Sarebbe un dato esatto e inutile — il modo peggiore di sbagliare, perché sembra funzionare.

Il compose apre l'isolamento in tre punti precisi: pid: host (i processi della macchina), network_mode: host (le porte e le interfacce vere, e la sonda raggiungibile), /:/hostfs:ro (il filesystem e /proc della macchina, in sola lettura). L'agente legge SNAP_AGENT_HOSTFS e punta lì psutil.PROCFS_PATH.

Anche così quattro gruppi restano fuori, e si dichiarano:

GRUPPO	PERCHÉ NON SI PUÒ
aggiornamenti	li conosce il gestore di pacchetti della macchina, con le sue liste e le sue chiavi: puntarci --admindir non basta
servizi	systemctl parla con il systemd della macchina
container	servirebbe il socket di Docker, che non si monta per non dare il controllo del motore
pianificate	i cron si leggono dal filesystem, i timer di systemd no: l'elenco si dichiara parziale

software invece funziona, perché l'agente punta all'archivio dei pacchetti della macchina (dpkg-query --admindir, rpm --dbpath). Senza quell'accortezza elencava i pacchetti dell'immagine Debian come se fossero quelli della macchina: è il difetto che ha motivato AG-11.

In sintesi: il container va bene per i server di cui interessano carico, dischi, rete, porte e processi. Per l'inventario completo l'installazione nativa vede tutto.

7. Requisiti

ID	REQUISITO
SR-300	La sonda deve eseguire un motore di rilevazione su ciò che osserva, a cadenza configurabile
SR-301	Ogni rilevazione deve dichiarare regola, gravità, soggetto, prova e istante
SR-302	La stessa rilevazione sullo stesso soggetto non deve duplicarsi: si aggiorna
SR-303	Finché la linea di base è più giovane del periodo dichiarato, le rilevazioni non devono generare allarmi
SR-304	I sensori devono essere innestabili e dichiarare la propria disponibilità
SR-305	Le rilevazioni conferite devono entrare nel SIEM come eventi normalizzati
SR-310	L'agente deve autenticarsi con chiave propria e firmare ogni invio con marca temporale e nonce
SR-311	L'agente non deve accettare comandi dalla sonda
SR-312	L'agente deve accumulare e ritrasmettere quando la sonda non risponde
SR-312-bis	Un evento che descrive una condizione persistente non deve essere ripetuto a ogni invio: si riferisce al cambiamento di stato e si riarma a intervallo dichiarato
SR-305-bis	La console della sonda deve permettere di consultare i pacchetti già letti, le conversazioni e i nomi richiesti, con ricerca e filtro
SR-306	Il sensore del traffico deve essere disattivato per difetto e attivabile dichiarando l'interfaccia osservata
SR-307	Del traffico non deve essere conservato né trasmesso alcun byte di payload: solo fatti derivati dalle intestazioni e dai nomi in chiaro
SR-308	Il traffico generato dalla sonda stessa deve essere escluso dall'osservazione
SR-309	Ogni contenitore dell'osservatorio deve avere un limite superiore, e il superamento deve essere dichiarato
SR-315	La raccolta deve essere divisa in gruppi dichiarati, attivabili singolarmente, e i gruppi disattivati devono essere comunicati alla sonda
SR-316	L'interfaccia di scelta dell'agente non deve richiedere alcuna porta in ascolto sulla macchina sorvegliata
SR-317	Le misure e l'inventario devono viaggiare separati, con cadenze proprie; l'inventario deve essere conservato come stato e sovrascritto
SR-318	Il pacchetto di installazione deve contenere tutto il necessario e un token a uso singolo, che gli installatori devono rimuovere dalla macchina una volta speso
SR-319	In esecuzione dentro un container, un gruppo che non può leggere la macchina ospite deve dichiararsi non misurato, mai riferire dati del container

ID	REQUISITO
SR-313	L'agente non deve raccogliere contenuti, ma solo misure e fatti
SR-314	La console deve mostrare rilevazioni, regole, sensori e macchine con agente, dichiarando ciò che non è stato osservato

8. Privacy e conformità

L'agente raccoglie nomi utente e sessioni: sono dati personali (GDPR art. 4). La base giuridica è la stessa dell'inventario — sicurezza della rete, art. 6(1)(f) — e le conseguenze pratiche sono tre: non si raccolgono contenuti (§6.2), la conservazione è a termine come per il resto dell'archivio, e le pagine nominano macchine e utenze, non persone.

Per NIS2 le rilevazioni sono il materiale della notifica di incidente: portano l'istante del rilevamento, il soggetto, la prova e la tecnica riconosciuta.

9. Come si legge: sei casi

I casi che seguono sono scritti nella forma in cui arrivano davanti a chi guarda: la riga che compare, la domanda che si pone, e che cosa la distingue da un falso allarme. Nessuno di essi è un esercizio: cinque sono accaduti durante il collaudo su una rete reale, il sesto è la ragione per cui l'IDS tace le prime dodici ore.

Caso 1 – La porta di amministrazione comparsa

alta · PORTA-AMMINISTRAZIONE · 10.20.14.31:3389 · T1021 amministrazione comparsa su 10.20.14.31 prova: porta 3389 dove non rispondeva (noto dal 2026-09-02 08:14)

Che cosa dice. Non "la 3389 è aperta" — questo la relazione sull'esposizione lo dice già, e su una rete grande sono decine. Dice che su quella macchina, dove per undici giorni non rispondeva, adesso risponde.

Come si decide. Due domande, in quest'ordine: qualcuno ha chiesto il desktop remoto su quella macchina? e quella macchina doveva averlo? Se la risposta alla prima è sì, si archivia con la nota «abilitato su richiesta del reparto X il 13/09» — e la nota resta, perché fra sei mesi nessuno se ne ricorderà. Se è no, è un incidente: qualcuno ha abilitato un accesso remoto senza dirlo. Il falso allarme tipico. Una macchina reinstallata. Il sistema torna con i servizi predefiniti attivi, e la 3389 ricompare per un motivo che non ha niente di malevolo. La prova lo suggerisce: se nello stesso giro compare anche ARP-MAC-CAMBIATO sullo stesso indirizzo, non è la stessa macchina di prima.

Caso 2 – Lo stesso indirizzo con una scheda di rete diversa

alta · ARP-MAC-CAMBIATO · 10.20.10.1 · T1557 10.20.10.1 risponde con una scheda di rete diversa prova: prima 00:1b:17:00:01:18, adesso 2c:21:72:5f:aa:03 (noto dal 2026-08-29)

Che cosa dice. L'indirizzo è lo stesso, il ferro no.

Come si decide. Su un gateway — e questo lo è — la faccenda è seria: è la forma che prende un attacco in mezzo alla comunicazione. Su una postazione è quasi sempre banale: una scheda sostituita, un portatile che ha preso l'indirizzo lasciato libero da un altro, una docking station cambiata. La zona del nodo è la prima cosa da guardare, e il costruttore del MAC la seconda: se il MAC nuovo appartiene a un costruttore di apparati di rete e quello vecchio a un produttore di portatili, qualcosa non torna.

Il falso allarme tipico. DHCP con lease corti e un pool piccolo: gli indirizzi girano, e la regola vede cambiare il MAC di un IP ogni pochi giorni. In una rete così, la si guarda solo nelle zone a indirizzamento statico.

Caso 3 – SMB 1.0 riaccesso

alta · SMB1-RIACCESO · 10.20.22.7 · T1210 10.20.22.7 accetta di nuovo SMB 1.0 prova: il dialetto NT LM 0.12 era assente alla lettura precedente

Che cosa dice. Un protocollo che era stato spento è tornato. È il protocollo di WannaCry: non è una regola di stile.

Come si decide. Quasi sempre c'è un colpevole innocente e noto: una stampante di rete vecchia, uno scanner che deposita su una condivisione, un gestionale che non è mai stato aggiornato. La domanda giusta non è chi lo ha riaccesso ma che cosa lo ha preteso. Si archivia con quel nome scritto nella nota, e si apre un'attività per sostituire la cosa che lo pretende.

Attenzione al confronto con la relazione SMB. Quella elenca tutte le macchine con SMB1 attivo (nel collaudo: 132). Questa ne segnala una sola: quella che l'ha riaccessato. Sono due domande diverse e servono entrambe.

Caso 4 – L'antivirus fermo, visto da dentro

critica · SICUREZZA-FERMA · ised-7007-dell-2ca964cf/Defender · T1562 nessun antivirus attivo fra i 2 registrati sensore: agenti

Che cosa dice. Dalla rete questa cosa non si vede: una macchina senza protezione risponde alle porte esattamente come una protetta. La riferisce l'agente, ed è il motivo per cui l'agente esiste.

Come si decide. È l'unica regola di gravità critica del catalogo, e si guarda subito. Disattivare la protezione è il passo che precede quasi tutto il resto.

Il falso allarme che abbiamo trovato noi. Durante il collaudo la regola scattava su una macchina protetta: l'agente interrogava il servizio di Defender, ma su quella macchina l'antivirus era di un altro produttore e Defender era fermo perché doveva esserlo. Adesso l'agente interroga il centro sicurezza di Windows, che elenca tutti i prodotti registrati, e segnala solo se nessuno di essi risulta attivo. La lezione vale oltre il caso: una regola che guarda un prodotto invece della funzione produce allarmi su chi ha fatto la scelta giusta.

Caso 5 – Il disco che finisce

alta · genere disco_pieno · ised-7007-dell spazio quasi esaurito su C:\: 97.7% di 475.8 GB

Che cosa dice. È il guasto più prevedibile che esista, ed è la ragione per cui l'agente raccoglie i dischi: non è sicurezza, è continuità operativa — e chi guarda gli incidenti è la stessa persona.

Come si legge la ripetizione — e perché non c'è più. Nella prima versione dell'agente questo evento si ripresentava a ogni invio finché la condizione durava: centotto righe identiche in ventiquattr'ore, e la pagina degli eventi non serviva più a niente. Dalla 1.0.2 una condizione si riferisce quando cambia di fascia (il 97,8% e il 97,9% sono la stessa notizia; il 92% e il 97% no) e si riarma dopo sei ore, così un problema che dura non sparisce in silenzio (AG-06). Se la condizione rientra, l'agente se ne dimentica subito: quando risale lo dice di nuovo senza aspettare il riarmo.

Caso 6 – Il silenzio delle prime dodici ore

(nessuna rilevazione) Memoria ancora giovane. La sonda probe-office-ised conosce 9.889 soggetti da 0.2 ore.

Che cosa dice. Che il motore sta ancora imparando, e che lo zero in cima alla pagina non è una buona notizia.

Perché esiste. Alla prima passata sulla rete di collaudo l'IDS ha prodotto quattrocento rilevazioni HOST-NUOVO: era corretto — non aveva mai visto nessuno di quei nodi — ed era inutile. Quattrocento allarmi il primo giorno sono il modo più rapido per far disattivare un IDS. Da qui la regola: finché l'archivio di ciò che era normale è più giovane di dodici ore, le regole fondate sull'assenza di memoria costruiscono la linea di base e tacciono (IDS-06).

Che cosa fare nel frattempo. Niente, ma saperlo: la pagina lo dichiara in un avviso, e la colonna «memoria» della pagina dei sensori dice per ciascuna sonda a che punto è. Dopo dodici ore l'avviso sparisce da solo.

Come si usa la pagina in un turno

1. Si aprono le rilevazioni aperte, che arrivano già ordinate per gravità.
2. Per ognuna si legge la prova prima del titolo: il titolo dice che cosa, la prova dice rispetto a quando.
3. Si decide: atteso > si archivia con la nota che dice perché; non atteso > si apre un incidente dalla pagina del SIEM, dove la stessa rilevazione è già arrivata come evento.
4. Prima di chiudere il turno con zero rilevazioni si guarda Regole e sensori: se due sensori su tre non stanno osservando, quello zero non significa quello che sembra.

10. Limiti dichiarati

- Nessuna ispezione del contenuto (§4.3): niente firme su payload. Un exploit riconoscibile solo dai byte che trasporta non viene visto; un canale di comando si riconosce dal ritmo e dal nome, non da ciò che dice.
- Senza porta mirror si vede il broadcast e il traffico diretto alla sonda: bastano per gli attacchi di segmento, non per le conversazioni fra altri.



- Il sensore d'inventario vede quanto spesso la sonda guarda: fra due passate un cambiamento passa inosservato. Le cadenze sono dichiarate nella console.
- L'agente vede una macchina sola: una compromissione che non tocca né i suoi processi né i suoi accessi non lascia tracce per lui.
- La linea di base impara ciò che trova: se una porta di amministrazione era già aperta al primo giro, per l'IDS è normale. La relazione sull'esposizione, che invece la segnala sempre, resta il posto dove guardare per quello.